

跨站请求伪造（CSRF）实验补充说明

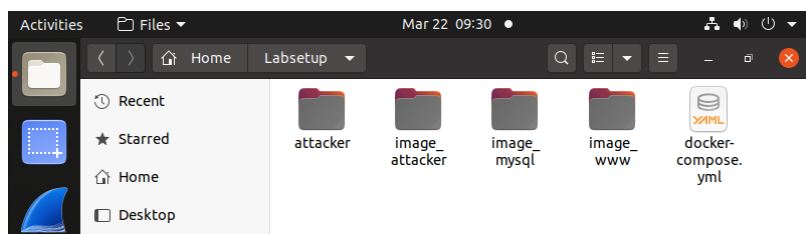
1 概述

你需要按照 SEED Labs 实验手册（Homework_2_Manual_Web_CSRF_Elgg.pdf，有中英文版）填写作业模板（Homework_2_template.docx）完成作业 2。从作业 2 开始的很多作业涉及在虚拟机上从 Docker Hub 下载实验用的容器镜像，从国内访问 Docker Hub 经常不稳定，需要通过 Docker 代理。本文档将对实验中进行的一些操作进行具体说明，方便你顺利完成作业。

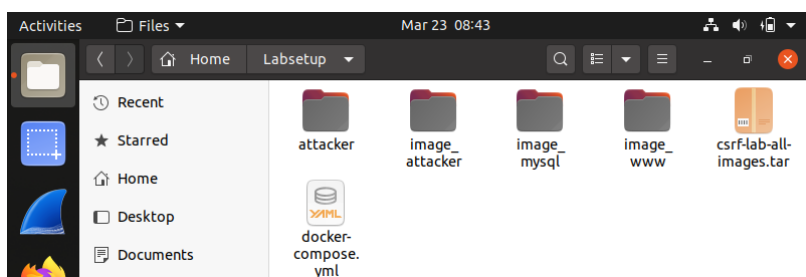
名词解释：Docker 容器镜像预先设置好了漏洞、实验工具等内容，给 Seed Labs 提供网络安全实验环境。Docker Hub 是用来分享 Docker 容器镜像的云盘，相当于 GitHub。

2 实验环境搭建

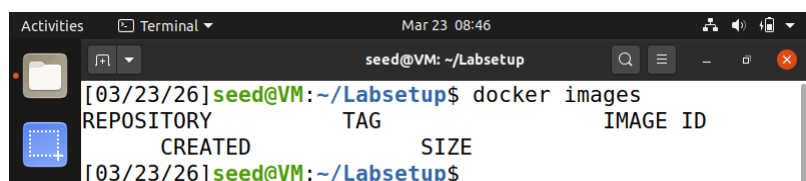
首先，需要你下载作业文件中的 Labsetup.zip，并将其中的 Labsetup 文件夹解压到 Home 目录下，之后的操作大多数在这个文件夹里完成。你需要先把压缩文件通过共享文件夹传输到虚拟机里，将其放在 Home 目录下，再右键点击，选择 Extract Here。不要在自己电脑上解压缩再传到虚拟机。结果如下图所示：Labsetup 文件夹在 Home 目录下，内含 4 个文件夹和 1 个 yml 文件。



为了更快地建立容器镜像，已经在 Teams 的 课程-Homework Files 文件夹中提供了对应压缩包：csrf-lab-all-images.tar，其 md5 值为 45fcef71f5dc3e6ad9354d69bd9fdf4f。下载该压缩包后，通过共享文件夹把它传到虚拟机，再复制到 Labsetup 文件夹（不要解压缩），如下图所示：



在 Labsetup 文件夹里打开终端窗口，首先运行 `docker images` 指令查看已安装的镜像：



可以看到只有表头，没有任何已安装镜像。运行下面的指令加载镜像：

```
docker load -i csrf-lab-all-images.tar
```

之后需约 10 秒钟加载完成，如图所示：

```

seed@VM: ~/Labsetup
ef4a33cee7a0: Loading layer 338.4kB/338.4kB
74c86dffd46f: Loading layer 9.539MB/9.539MB
6d23902c2a54: Loading layer 4.2MB/4.2MB
c484a3b6d841: Loading layer 1.536kB/1.536kB
0394a41efa73: Loading layer 53.76MB/53.76MB
98d98806c8ac: Loading layer 6.656kB/6.656kB
31c817234280: Loading layer 3.584kB/3.584kB
886316cd2456: Loading layer 410.2MB/410.2MB
ab4149930225: Loading layer 5.632kB/5.632kB
a9d9d14a1b5f: Loading layer 16.38kB/16.38kB
9a3a2a8be646: Loading layer 1.536kB/1.536kB
8418f559bddb: Loading layer 98.3kB/98.3kB
Loaded image: seed-image-mysql-csrf:latest
acc71ab7a3e0: Loading layer 4.608kB/4.608kB
a642c6617ce1: Loading layer 7.168kB/7.168kB
Loaded image: seed-image-attacker-csrf:latest
Loaded image: handsonsecurity/seed-elgg:original
Loaded image: handsonsecurity/seed-server:apache-php
Loaded image: mysql:8.0.22
[03/23/26]seed@VM:~/Labsetup$

```

可以运行 `docker images` 指令再次查看已安装的镜像，应该有以下图中的 6 项。若有缺失，将无法进行下一步。

```

[03/23/26]seed@VM:~/Labsetup$ docker images

```

REPOSITORY	TAG	IMAGE ID	CREATED	SIZE
seed-image-attacker-csrf	latest	0801b817246a	8 hours ago	261MB
seed-image-mysql-csrf	latest	c6dd466ca348	8 hours ago	545MB
seed-image-www-csrf	latest	0598a42e5136	8 hours ago	403MB
handsonsecurity/seed-elgg	original	b5a8ba77f28a	5 months ago	403MB
mysql	8.0.22	d4c3cafb11d5	5 years ago	545MB
handsonsecurity/seed-server	apache-php	2365d0ed3ad9	5 years ago	261MB

```

[03/23/26]seed@VM:~/Labsetup$

```

然后运行 `dcbuild` 指令建立容器镜像。大概需要 10 秒钟，在建立容器镜像成功后会看到下图：

```

Enabling site server_name.
To activate the new configuration, you need to run:
    service apache2 reload
Enabling site apache_attacker.
To activate the new configuration, you need to run:
    service apache2 reload
Removing intermediate container 85d02b21613c
--> 524589161c9d

Successfully built 524589161c9d
Successfully tagged seed-image-attacker-csrf:latest
[03/23/26]seed@VM:~/Labsetup$

```

在运行 `dcup` 指令启动服务器之前，需要编辑 `/etc/hosts` 文件（对应实验手册 2.3 的 DNS 配置部分）。

在 Home 目录中打开终端窗口，输入以下命令，用 root 权限打开文本编辑器并编辑 `hosts` 文件。

```
sudo gedit /etc/hosts
```

随后在打开的文本编辑器中找到 `# For CSRF Lab` 这一段（应该在文件第 25 行），将它下面的三行作如下修改：

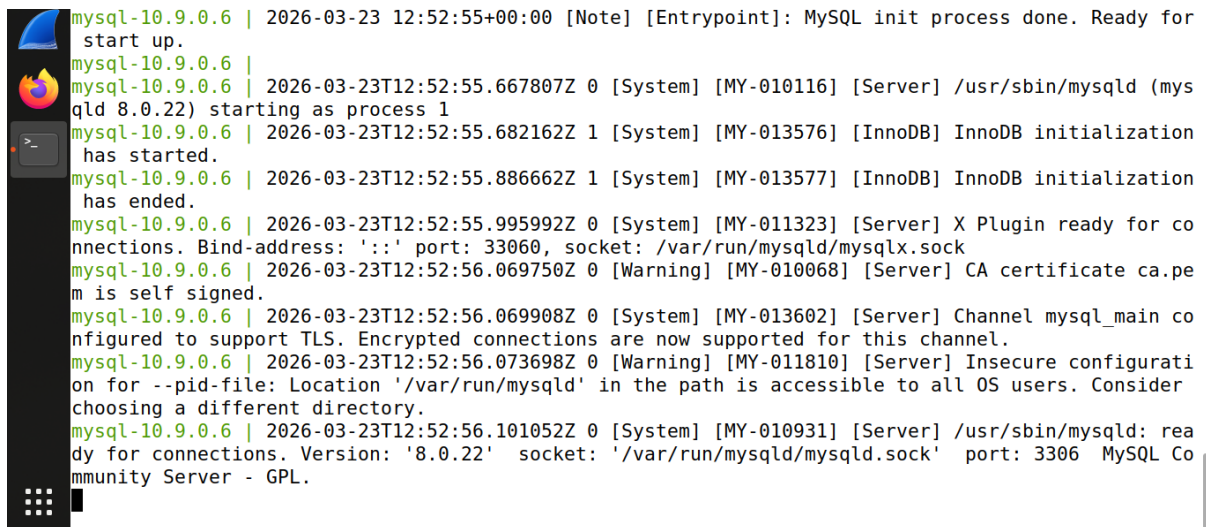
```

10.9.0.5      www.seed-server.com
10.9.0.5      www.example32.com
10.9.0.105    www.attacker32.com

```

完成编辑后，点击保存，然后可以关闭文本编辑器。

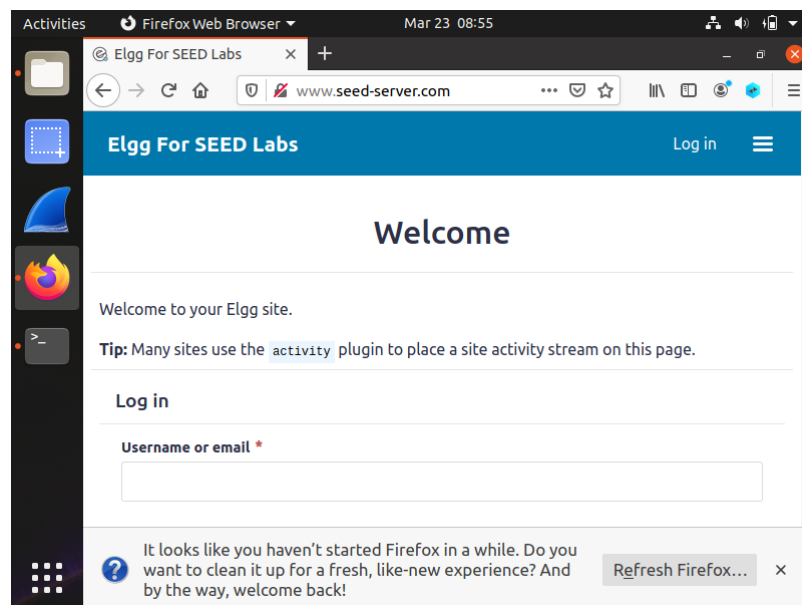
现在可以在 Labsetup 文件夹里打开终端窗口并执行 **dcup** 指令启动服务器。成功效果如下图所示：



```
mysql-10.9.0.6 | 2026-03-23 12:52:55+00:00 [Note] [Entrypoint]: MySQL init process done. Ready for
start up.
mysql-10.9.0.6 |
mysql-10.9.0.6 | 2026-03-23T12:52:55.667807Z 0 [System] [MY-010116] [Server] /usr/sbin/mysqld (mys
qld 8.0.22) starting as process 1
mysql-10.9.0.6 | 2026-03-23T12:52:55.682162Z 1 [System] [MY-013576] [InnoDB] InnoDB initialization
has started.
mysql-10.9.0.6 | 2026-03-23T12:52:55.886662Z 1 [System] [MY-013577] [InnoDB] InnoDB initialization
has ended.
mysql-10.9.0.6 | 2026-03-23T12:52:55.995992Z 0 [System] [MY-011323] [Server] X Plugin ready for co
nnections. Bind-address: '::' port: 33060, socket: /var/run/mysqld/mysqlx.sock
mysql-10.9.0.6 | 2026-03-23T12:52:56.069750Z 0 [Warning] [MY-010068] [Server] CA certificate ca.pe
m is self signed.
mysql-10.9.0.6 | 2026-03-23T12:52:56.069908Z 0 [System] [MY-013602] [Server] Channel mysql_main co
nfigured to support TLS. Encrypted connections are now supported for this channel.
mysql-10.9.0.6 | 2026-03-23T12:52:56.073698Z 0 [Warning] [MY-011810] [Server] Insecure configurati
on for --pid-file: Location '/var/run/mysqld' in the path is accessible to all OS users. Consider
choosing a different directory.
mysql-10.9.0.6 | 2026-03-23T12:52:56.101052Z 0 [System] [MY-010931] [Server] /usr/sbin/mysqld: rea
dy for connections. Version: '8.0.22' socket: '/var/run/mysqld/mysqld.sock' port: 3306 MySQL Co
mmunity Server - GPL.
```

注意：为使服务器继续运行，你需要留着这个窗口继续运行（不能关闭）。它不会自动结束运行，也不会弹出下一个命令提示符。

在服务器继续运行的情况下，你可以打开火狐浏览器：，输入网址：www.seed-server.com。看到下面页面说明服务器运行正常：



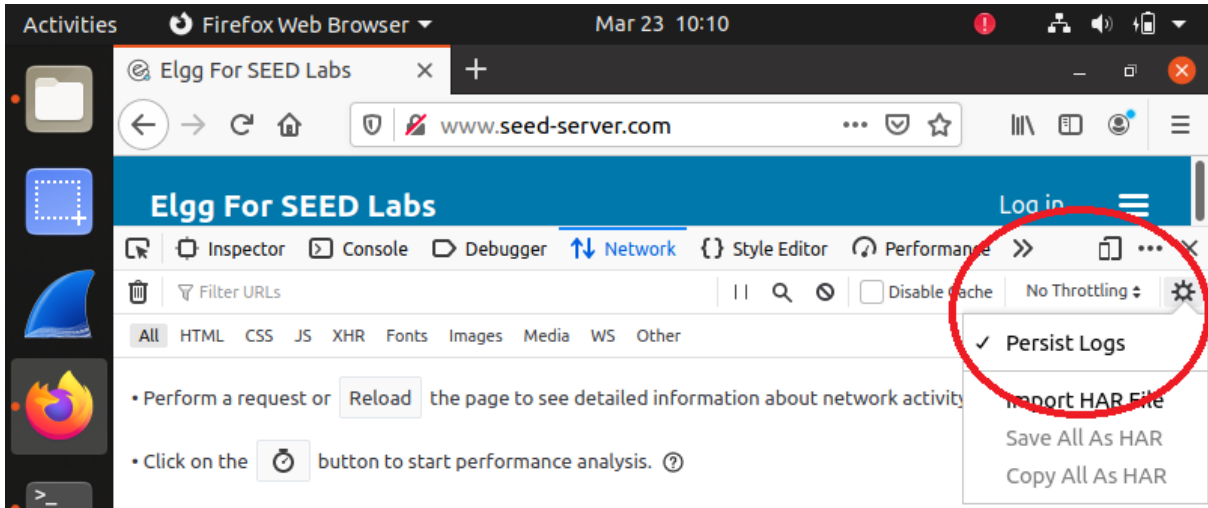
注意：勿点击 Refresh Firefox，也不要更新浏览器，可能有安全措施更新导致实验无法顺利进行。

如果你需要关闭服务器，需要在 Labsetup 文件夹打开另一个终端窗口并运行 **dcdowndown** 指令。这个指令运行完毕后，你可以看到两个终端窗口均输出停止信息并弹出命令提示符，表明服务器正常关闭。后续需要重新启动服务器时，在 Labsetup 文件夹打开终端窗口并运行 **dcup** 指令即可，不必再 **dcbuild**。

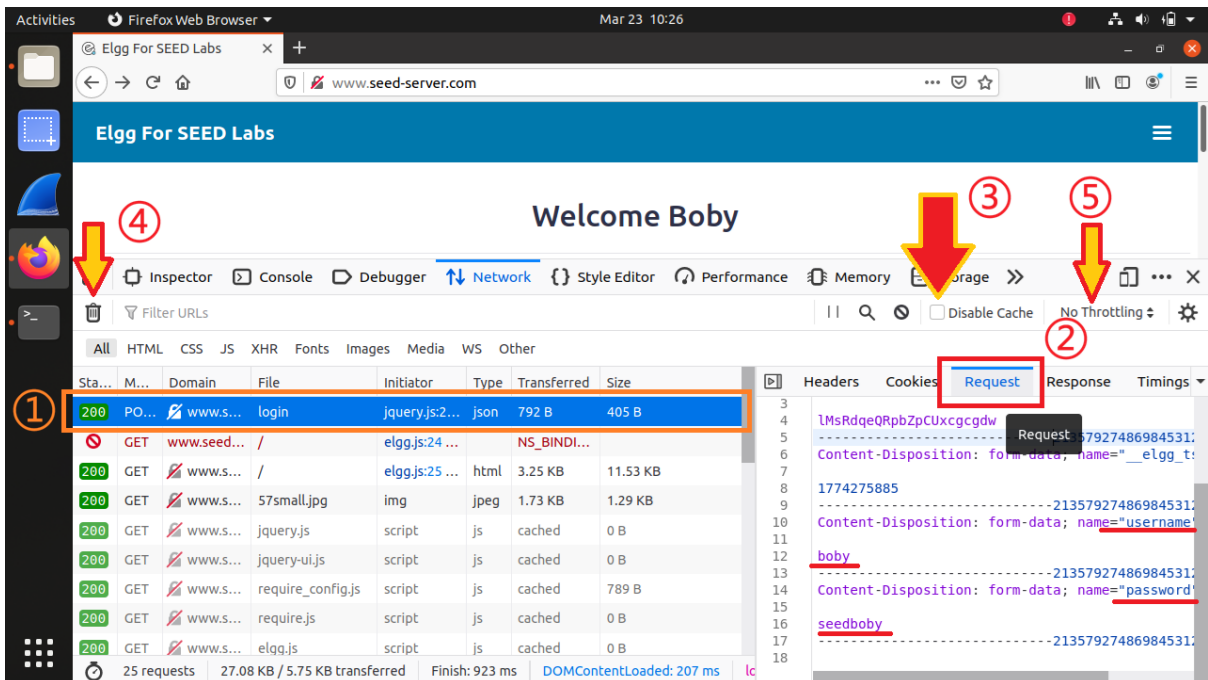
3 实验任务：攻击

3.1 任务 1：观察 HTTP 请求

实验手册中提到的扩展程序“HTTP Header Live”会因 Firefox 浏览器自动移除而无法运行。你需要改用实验手册 5.2 中提到的 Firefox 浏览器自带的 Web 开发者工具。5.2 提到了这个工具的开启方式，但你也可以直接在 Firefox 浏览器里按 F12 打开，再点击 Network 标签。需要注意的是，该工具的默认设置无法捕获 POST 请求，你需要点击界面右上角齿轮标志，之后选择 Persist Logs（确保前面打勾，如下图所示）

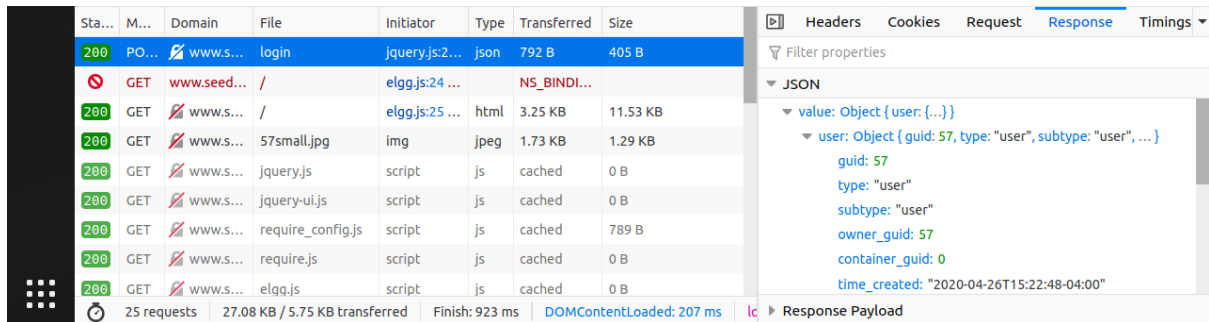


现在你可以在 www.seed-server.com 网站上尝试登录等操作，再观察网络通信内容了。例如，试着登录 boby 账户（对应实验手册 2.3 的用户账户部分），同时观察 Network 选项卡下面的网络通信，发现：



橙色框①显示你作为用户向服务器发送的登录请求，它在整个网络通信列表中的顶部，意味着它是最先发出的信息。右边点击 Request 选项卡②，可见用户实际发送的内容，例如红线标出用户名为 boby，密码为 seedboby。另外，建议勾选 Disable Cache③，避免缓存内容影响后续实验。每次进行点击链接

等操作，Network 内都会记录新的网络请求和回复，列表里的信息数量也会增加。如果你觉得信息太多不便查看，可以点击垃圾桶图标④，删除目前记录的所有信息。接下来，点击 Request 右侧 Response 选项卡，查看服务器的回复（如下）。如果有 Request 却无 Response，可能是你的虚拟机运行太快或是太慢，需要你点击 No Throttling⑤调到较慢的网速，如 Good 2G。



Sta...	M...	Domain	File	Initiator	Type	Transferred	Size
200	PO...	www.s...	login	jquery.js:2...	json	792 B	405 B
200	GET	www.seed...	/	elgg.js:24...	html	3.25 KB	11.53 KB
200	GET	www.s...	57small.jpg	img	jpeg	1.73 KB	1.29 KB
200	GET	www.s...	jquery.js	script	js	cached	0 B
200	GET	www.s...	jquery-ui.js	script	js	cached	0 B
200	GET	www.s...	require_config.js	script	js	cached	789 B
200	GET	www.s...	require.js	script	js	cached	0 B
200	GET	www.s...	elgg.js	script	js	cached	0 B

25 requests | 27.08 KB / 5.75 KB transferred | Finish: 923 ms | DOMContentLoaded: 207 ms

Response Payload

```

{
  "value": {
    "user": {
      "guid": 57,
      "type": "user",
      "subtype": "user",
      "owner_guid": 57,
      "container_guid": 0,
      "time_created": "2020-04-26T15:22:48-04:00"
    }
  }
}

```

这里包含了重要信息：boby 用户的全局用户 id (guid) 为 57。后续需要你用类似方法查看其他用户的 guid。此外，你需要寻找不登录某一用户也能查看该用户 guid 的方法。

3.2 任务 2：使用 GET 请求的 CSRF 攻击

实验手册里对如何完成这个任务语焉不详，实际的做法是：

1. Samy 修改自己控制的一个网页页面 (www.attacker32.com/addfriend) 的 html 源文件（在 Labsetup/attacker 文件夹中，文件名是 addfriend.html），使得任何访问这个网页页面的人都会向 www.seed-server.com 网站发送“添加 Samy 为我的好友”请求。你可以使用 gedit 打开这个 html 源文件并修改，类似上文里修改 hosts 文件。
2. 为了获取这条请求的实际内容，需要你登录某人账户（严格来说，Samy 作为攻击者，只能登录他自己的账户并进行操作），并添加某个用户为好友，同时用 3.1 中的火狐网页开发者工具查看请求的内容。之后把这条内容做对应修改后添加到 html 源文件里。
3. 假设 alice 在已经登录 seed-server 网站的情况下误点击 www.attacker32.com/addfriend，她的浏览器也会向 seed-server 网站发送“添加 Samy 为我的好友”请求。因为她已经登录，她的浏览器会在发送请求时附上她之前获取的 Cookie，seed-server 网站会识别为：alice 试图添加 Samy 为她的好友，并执行此操作。这样就完成了 3.2 的任务内容。

补充：seed-server 网站添加好友的操作是单向的，即：A 可以不经 B 同意将 B 加为好友，但在 B 的视角中，A 仍不是他的好友。或者说，比起“好友”，这个操作更像是“关注”。此外，第一次接触这个网站的用户很难自己发现如何添加好友：需要登录后点击右上角的三横线图标，选择 Members 查看现有用户列表，点击你想加为好友的用户名，再点击 Add friend。

3.3 任务 3：使用 POST 请求的 CSRF 攻击

实验手册里对如何完成这个任务的描述详细了许多，只需注意：这次要修改的源文件是 Samy 作为攻击者控制的另一个网页页面 (www.attacker32.com/editprofile) 的 html 源文件（在 Labsetup/attacker 文件夹中，文件名是 editprofile.html），需要修改的部分也变多了。

4 实验任务：防御

4.1 任务 4：启用 Elgg 的防护措施

本任务会导致页面无限循环（见实验手册任务：开启防护措施一节），可能导致虚拟机崩溃。你无需完成此任务，但你需要回答作业模板中关于此任务的问题（可通过分析实验手册中代码回答问题）。

4.2 任务 5: 实验 SameSite Cookie 方法

本任务与之前任务无关。你需要在 www.example32.com 中打开 Web 开发者工具，并点击 Storage 选项卡，左侧列表里可以找到 Cookies 并查看。在作业模板中说明了你在此任务里要回答的问题和要保留的截图。本任务无额外加分。

5 指导方针

此章节没有需要完成的任务。需注意，由于火狐浏览器版本不同，实验手册 5.2 中对 Web 开发者工具的描述和本补充说明中的略有不同。

6 提交作业

请在作业 2 模板 (Homework_2_Template.docx) 上完成，**生成 pdf 文件并提交**。不要提交 .docx 文件。

作业中需要提交多张截图，请用虚拟机的截图功能截图。请勿手机拍屏。

本次作业没有其他需要提交的文件。

7 附录

如果你不想使用 Teams 上下载的 .tar 文件，可以直接按实验手册执行 dcbuild 指令，但这之前需要设置 Docker 代理。此处的解决方法来自官方中文解决方案：

https://gitee.com/seedlab/seedlabs-chinese/blob/master/manuals/docker_proxy.md

在 Home 目录中打开终端窗口，输入以下命令，用 root 权限打开文本编辑器并编辑 daemon.json 文件。

```
sudo gedit /etc/docker/daemon.json
```

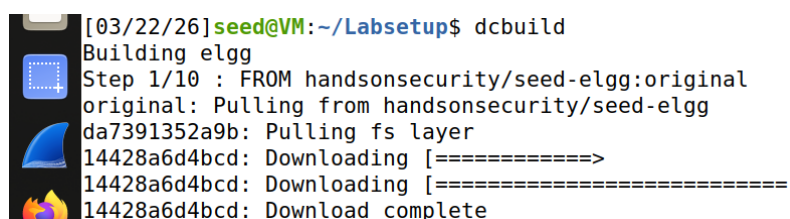
随后在打开的文本编辑器中添加下述文本，把代理网站添加到列表，设置 Docker 代理（注意，如果 pdf 文件复制有问题，你可以在上面网址里复制），完成编辑后，点击保存并关闭文本编辑器。

```
{
  "registry-mirrors":[
    "https://docker.1panel.live",
    "https://docker.anyhub.us.kg",
    "https://dockerhub.icu"
  ]
}
```

之后，在终端窗口中依次执行下面两条指令，重新载入代理网站列表并重启 docker：

```
sudo systemctl daemon-reload
sudo systemctl restart docker
```

这两条指令运行后没有提示文字，只会弹出下一个命令提示符，代表执行成功。接下来可以在 Labsetup 文件夹里打开终端窗口，运行 dcbuild 指令建立容器镜像。如下图所示，运行 dcbuild 指令后会显示下载进度。这一步需要下载多个文件，在校园网下载会比较缓慢。下载完成后可以按实验手册步骤继续进行，执行 dcup 指令。



```
[03/22/26]seed@VM:~/Labsetup$ dcbuild
Building elgg
Step 1/10 : FROM handsonsecurity/seed-elgg:original
original: Pulling from handsonsecurity/seed-elgg
da7391352a9b: Pulling fs layer
14428a6d4bcd: Downloading [=====>]
14428a6d4bcd: Downloading [=====]
14428a6d4bcd: Download complete
```